



Module 12 Day 3: Enterprise Security Management (ESM)

Class Instruction

Overview

In today's class, you will advance your network security knowledge by learning enterprise security management (ESM) and how host-based OSSEC IDS technology plays a critical role in endpoint telemetry. You will investigate threats using Security Onion's Elastic Stack and a web-based data analytics visualization tool called Kibana.

Class Objectives

By the end of today's class, you will be able to:

- Analyze indicators of attack for persistent threats.
- Use enterprise security management to expand an investigation.
- Use OSSEC endpoint reporting agents as part of a host-based IDS alert system.
- Investigate threats using various analysis tools.
- Escalate alerts to senior incident handlers.

Lesson Slideshow

The lesson slides are available on Google Drive here: [12.3 Slides](#)

01. Security Onion Setup

Security Onion Setup

Like the previous class, in preparation for the labs, everyone will need to log into Azure and connect to the Network Security environment. After you are connected, launch an instance of Security Onion from the HyperV manager. The PCAP data should still be there from the previous class.

We'll begin today's class by verifying that the PCAP data is still there.

Log in to the Security Onion machine with the following credentials:

- Username: sysadmin
- Password: cybersecurity
- Run `sudo so-status`.
 - `so-status`: This command checks the status of all the components that make up Security Onion.
- Output should look similar to the following:

```
lsysadmin@securityonion ~1$ sudo so-status
```

Security Onion Status		
Container	Status	Details
so-curator	running	Up 23 hours
so-dockerregistry	running	Up 23 hours
so-elastalert	running	Up 23 hours
so-elastic-fleet	running	Up 23 hours
so-elastic-fleet-package-registry	running	Up 23 hours (healthy)
so-elasticsearch	running	Up 23 hours
so-idstools	running	Up 23 hours
so-influxdb	running	Up 23 hours (healthy)
so-kibana	running	Up 23 hours
so-kratos	running	Up 23 hours
so-mysql	running	Up 23 hours (healthy)
so-nginx	running	Up 23 hours (healthy)
so-playbook	running	Up 23 hours
so-sensoroni	running	Up 23 hours
so-soc	running	Up 23 hours
so-soctopus	running	Up 23 hours
so-steno	running	Up 23 hours
so-strelka-backend	running	Up 23 hours
so-strelka-coordinator	running	Up 23 hours
so-strelka-filestream	running	Up 23 hours
so-strelka-frontend	running	Up 23 hours
so-strelka-gatekeeper	running	Up 23 hours
so-strelka-manager	running	Up 23 hours
so-suricata	running	Up 23 hours
so-telegraf	running	Up 23 hours
so-zeek	running	Up 23 hours (healthy)

■ This onion is ready to make your adversaries cry!

- Ensure that all statuses are listed as running.
- If not, let the services run for about 5–7 minutes and run the `so-status` command again.
-
- If any of the statuses are not listed as running after the review, restart the NSM tools with the following command:
 - ``sudo reboot``
- Run the `so-status` command again for a few minutes. All systems should be listed as OK after a few minutes.

Generate Alerts

2. Next, verify that the PCAPs are still populated.

Verify that the PCAPs loaded from the previous class are still there. If the PCAP data is not available, use the following file and repeat the steps mentioned in **02. Replaying PCAPs**:

- [Activity File: Security Onion Setup](#)

02. Overview and Alert - C2 Beacon Setup

Network Security Recap

- On Day 1, we covered how firewalls protect a network. On Day 2, we expanded our layers of network security to cover IDS and IPS systems.
- Today, we will focus on how an adversary conducts network security attacks. Through a process known as cyber threat hunting, we will use advanced network security tools, such as Security Onion and ELK, to gain a deeper understanding and situational awareness of a network's security posture.

C2 Alert Beacon Set Up

This activity will apply your knowledge of NSMs.

- Before diving into the activity, let's take a look at C2 servers.

- Compromised servers make callbacks to C2 servers. These callbacks, referred to as "keep alives," serve as beacons that keep the back channel open and let the C2 servers know that they are ready to receive commands. This gives cybercriminals access in and out of the network at all times.
- These keep alive beacons activate a specific alert. In the screenshot, we see an alert identified as a C2 beacon activity. Note that it includes the text ET MALWARE Zbot POST Request to C2 in the Rule.

- There is a reference URL specified within the rule option.
 - Sometimes, writers of Suricata rules will put additional info in their rule message to help network defenders.
 - The example below shows the following message: Malware Command and Control Activity Detected
 - With this information, network defenders can form mitigation strategies to help improve their security posture.

© 2024 edX Boot Camps LLC. Confidential and Proprietary. All Rights Reserved.

03. Activity: C2 Beacon

- [Activity File: C2 Beacon](#)

04. Activity Review: C2 Beacon

05. Enterprise Security Management/Monitoring

Now that we've learned about the benefits of using firewalls and NSM, we must move from traditional network-based IDS engines, such as Snort, to more all-encompassing enterprise security monitoring (ESM), which includes endpoint telemetry.

OSSEC

Firewalls and NSM cannot see inside of encrypted traffic. This is major limitation because:

- In most cases, malware will be transmitted from attacker to victim in an encrypted state to hide its presence and intent. This also serves as a method of obfuscation to bypass IDS detection engines.
- Since malware cannot activate in an encrypted state, it must be decrypted. This can only happen after it is installed on the victim's machine. This is where ESM and, more specifically, endpoint telemetry become relevant.

ESM uses OSSEC (Open Source Security) to provide visibility at the host level, where malware infection takes place after it's decrypted.

- OSSEC is the industry's most widely used host-based IDS (HIDS). It has many configuration options and can be tailored to the needs of any organization.
- Endpoint telemetry involves host-based monitoring of system data.
 - OSSEC agents are deployed to hosts and collect syslog data. This data generates alerts that are sent to the centralized server, Security Onion.
 - Security administrators can then use Security Onion to form a detailed understanding of the situation and reconstruct a crime.

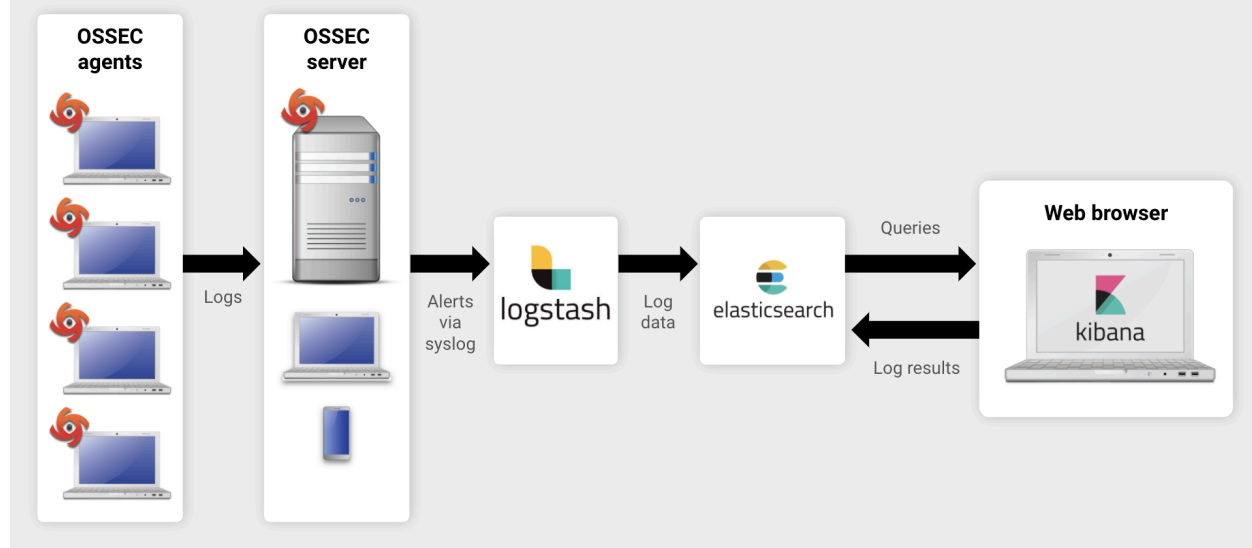
Elastic Stack

OSSEC monitors all of the syslog data that it sees. However, not every syslog entry will generate an alert. Security admins will need to switch to other tools to fully analyze packet captures.

These other tools are known as the Elastic (ELK) Stack, the engine that operates within Security Onion. It consists of three important components:

1. Elasticsearch is considered the heart of the Elastic Stack. It is a distributed, restful search and analytics engine built into Security Onion that is capable of addressing thousands of data points seen within network traffic. It helps security administrators locate the expected and uncover the unexpected.
2. Logstash is an open-source, server-side data processing pipeline built into Security Onion. It ingests data from many sources simultaneously by transforming it and sending it to designated log files, known as stashes.
3. Kibana is a browser-based visualization interface. It uses thousands of data points from the Elastic Stack as its core engine.

Elastic Stack



These tools work together with OSSEC to make a comprehensive alert data process:

1. OSSEC agents generate an alert.
2. OSSEC sends alert data gathered from syslog to Security Onion's OSSEC server.
3. The OSSEC-generated syslog alert is written to Logstash for storage.
4. Log data is ingested into the Elasticsearch analytics engine, which parses hundreds of thousands of data points to prepare for data presentation.
5. Users interact with the data through the Kibana web interface.

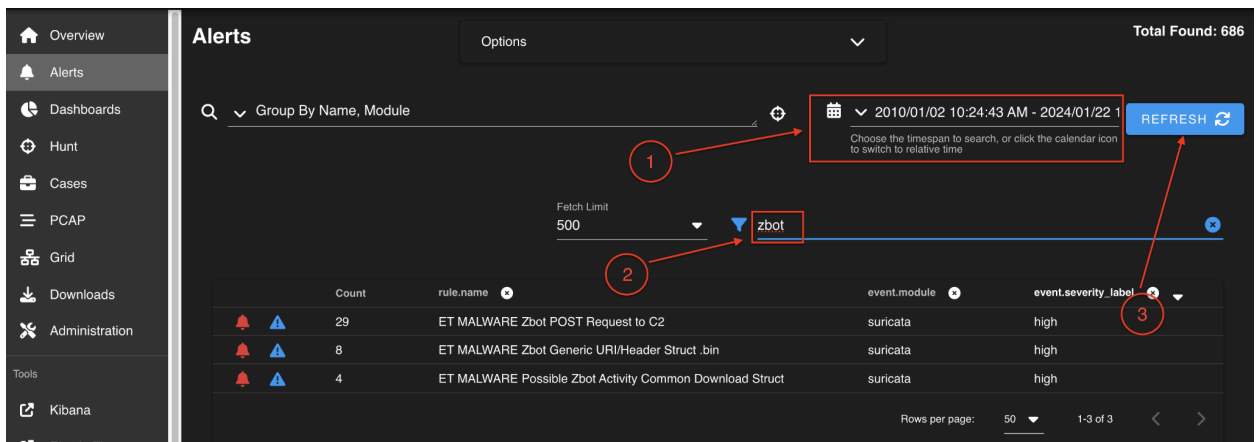
Investigation, Analysis, and Escalation Demo

In this demo, we will discuss using several tools in the ELK stack. We will focus on how these tools work, and not a specific attack.

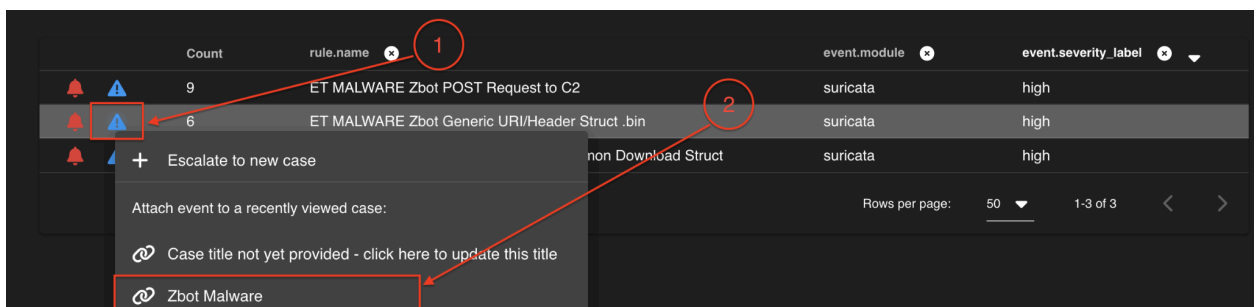
- We will also focus on the process of escalation within a Security Operations Center:
 - A junior analyst working in a Security Operations Center is part of a multi-tier group of analysts. Junior analysts typically perform the initial triage of alerts and then escalate these events to senior incident responders.
- This process and the tools involved will be our focus.

We'll continue our investigation by looking for more Zbot traffic:

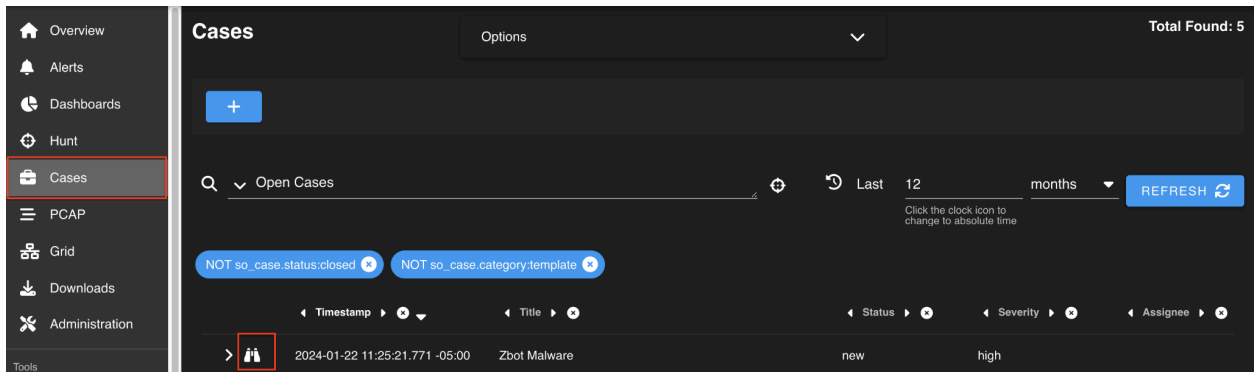
- In Security Onion, click on the Alerts icon and modify the way the alerts are displayed.
- We may need to change the date range to ensure we see all the alert data in our system. By default, it only displays the alerts from the last 24 hours. Make the following modifications.
 - Change the date range to start with 2010/01/02 and end with today's date.
 - Type Zbot into the filter.
 - Click Refresh to update the results.



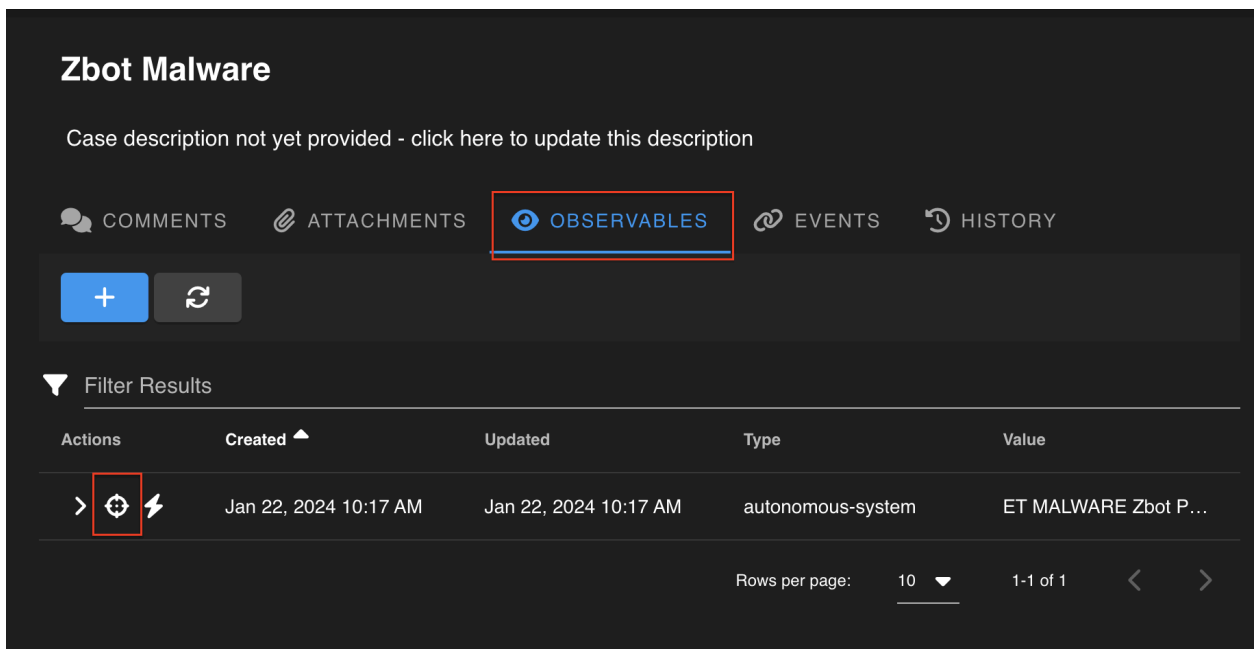
- The results show that there are other alerts that look like they might contain Zbot traffic. Add the ET MALWARE Zbot Generic URI/Header Struct .bin to the case that was created in the last activity.
 - Click the blue triangle with the exclamation point.
 - Select the Malware Zbot Case.



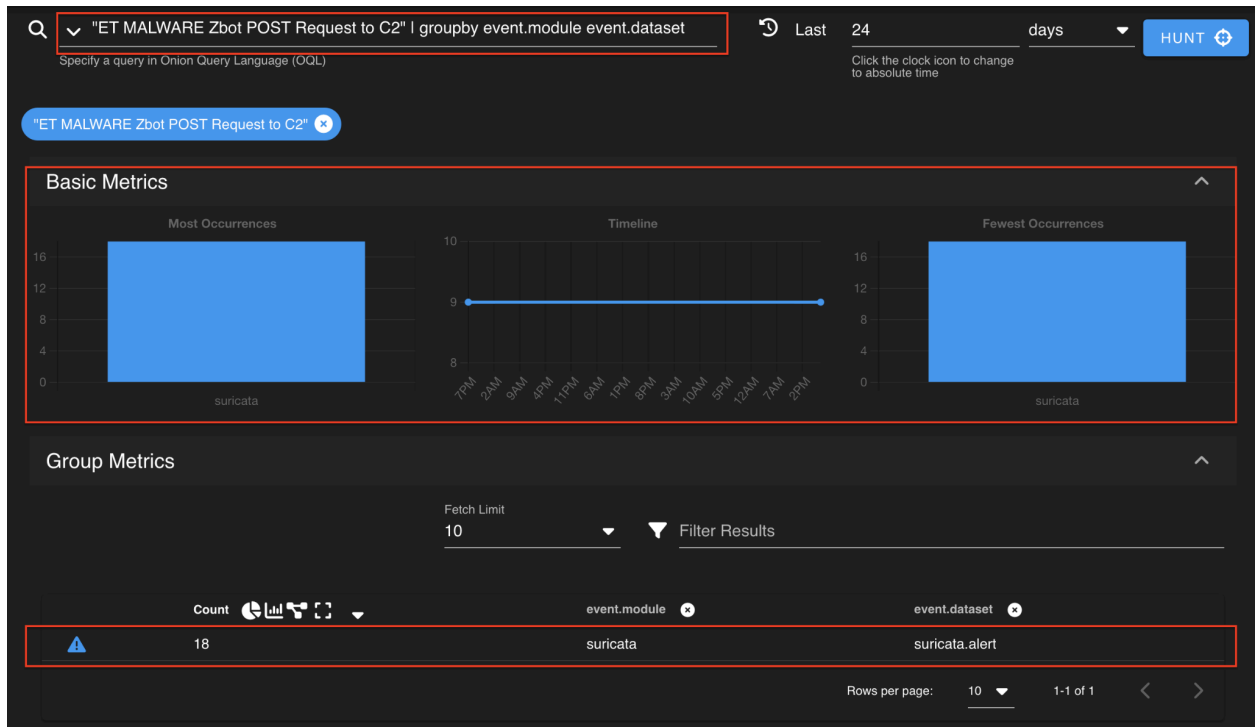
- Explain that we are now going to take a look at the status of the case we created.
 - Click on Cases on the left-hand side.
 - Then click the binoculars next to the case to view the case contents.



- From here, we can click on Observables and pivot to Hunt for additional instances of Zbot.
 - Click Observables.
 - Then click the crosshairs icon next to the observable.



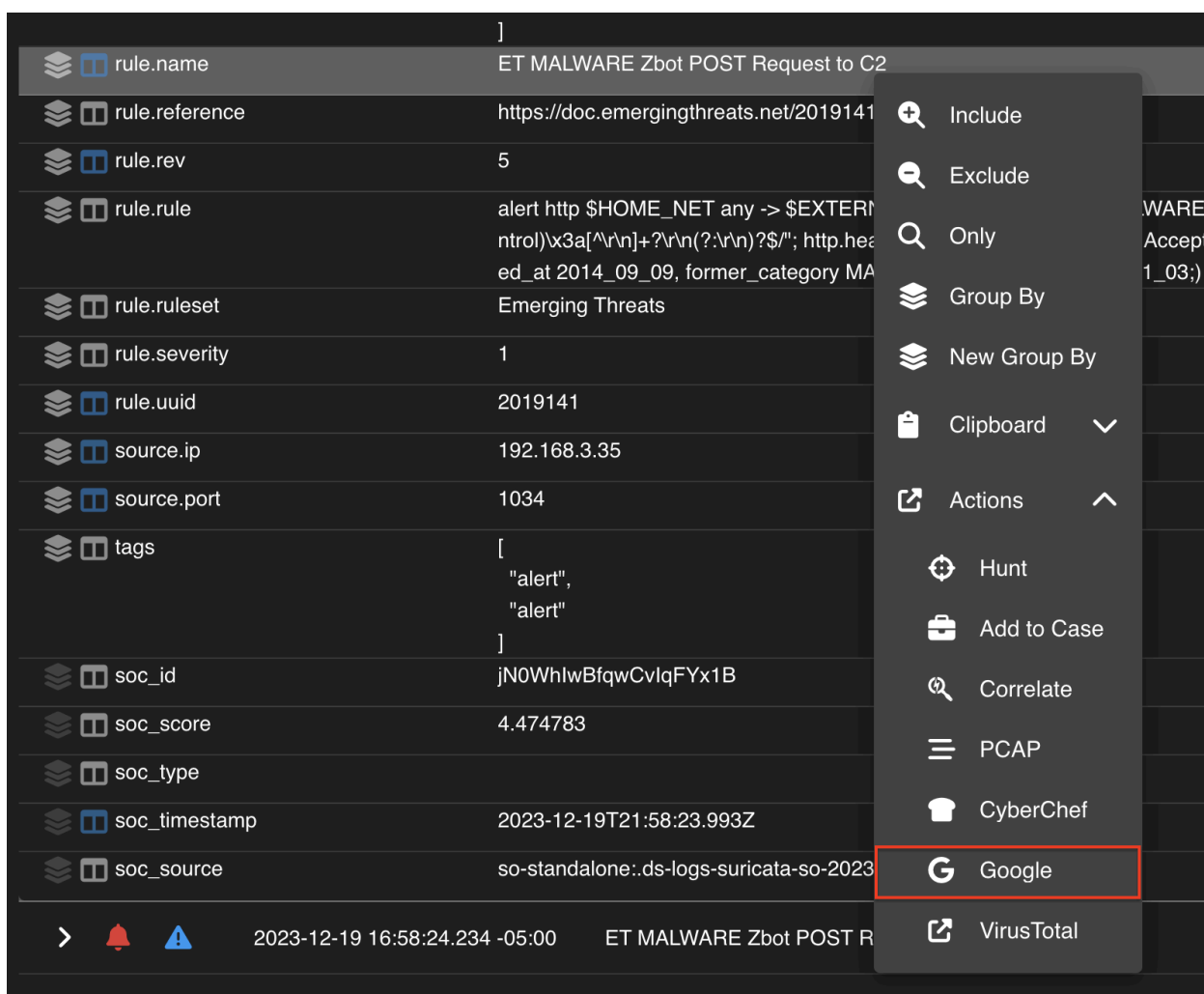
- We should now see the Hunt Dashboard. From here, we can see that ET MALWARE Zbot POST Request to C2 has been added to the SO Hunt Query. This will limit results to those containing that name.
 - The dashboard also presents some basic metrics in regards to the incident.
 - There is also an incident count.



- Scrolling down reveals all of the events that the query returns.
 - Within the event fields, we can see a reference URL that provides additional information about this particular type of Malware.

rule.name	ET MALWARE Zbot POST Request to C2
rule.reference	https://doc.emergingthreats.net/2019141
rule.rev	5
rule.rule	alert http \$HOME_NET any -> \$EXTERNAL_NET any (msg:"ET MALWARE Zbot POST Request to C2"; flow:established,to_server; http.metf ntrol)\x3a[^\r\n]+\?\r\n(?:\r\n)?\$/; http.header_names; content:"!0d 0a!Accept!0d 0a!User-Agent!0d 0a!Host!0d 0a!Content-Length!0d 0a!"; depl ed_at 2014_09_09, former_category MALWARE, updated_at 2020_11_03;)

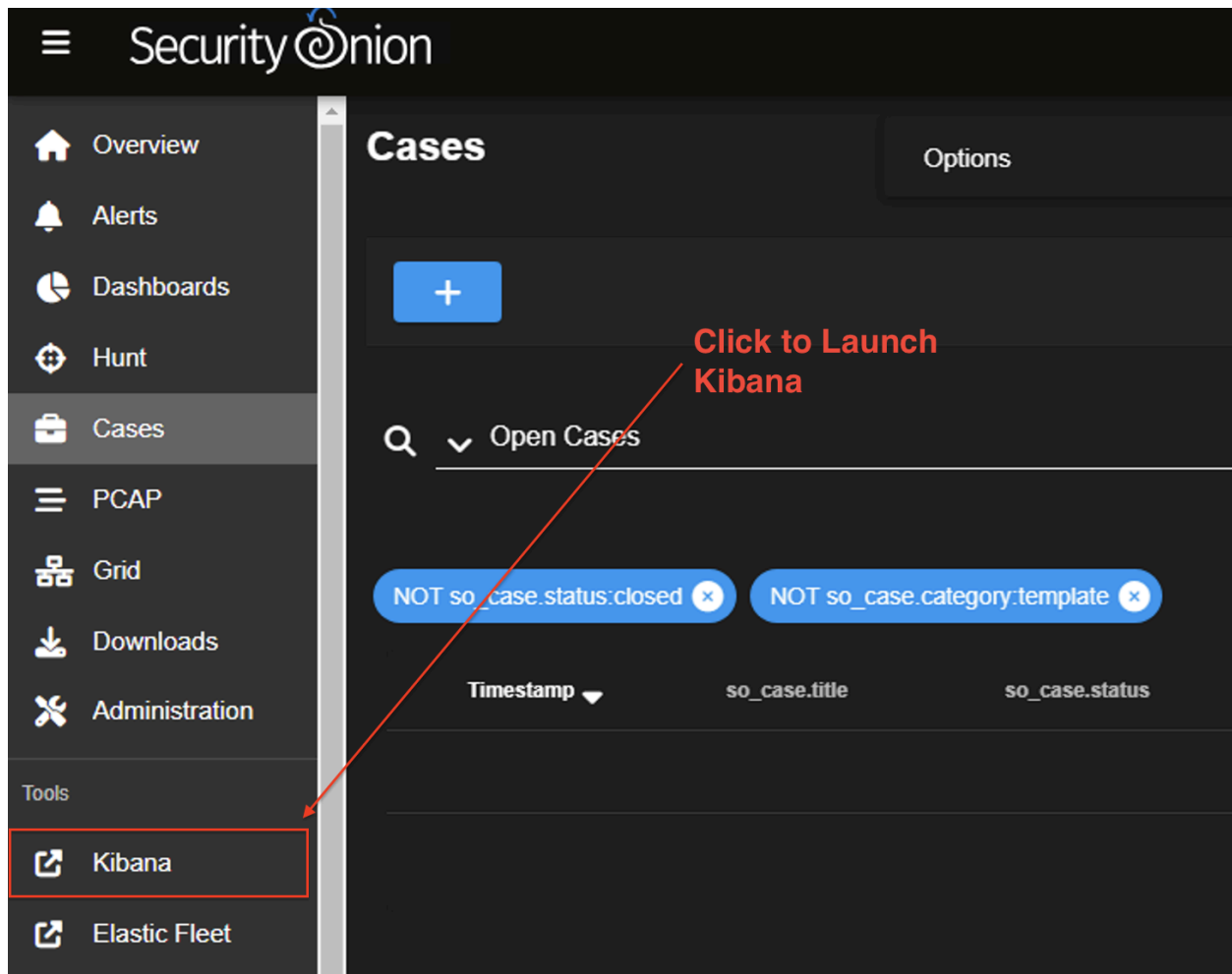
- We can also click on any field, such as rule name, and perform a quick Google search to learn more about that particular field's contents.



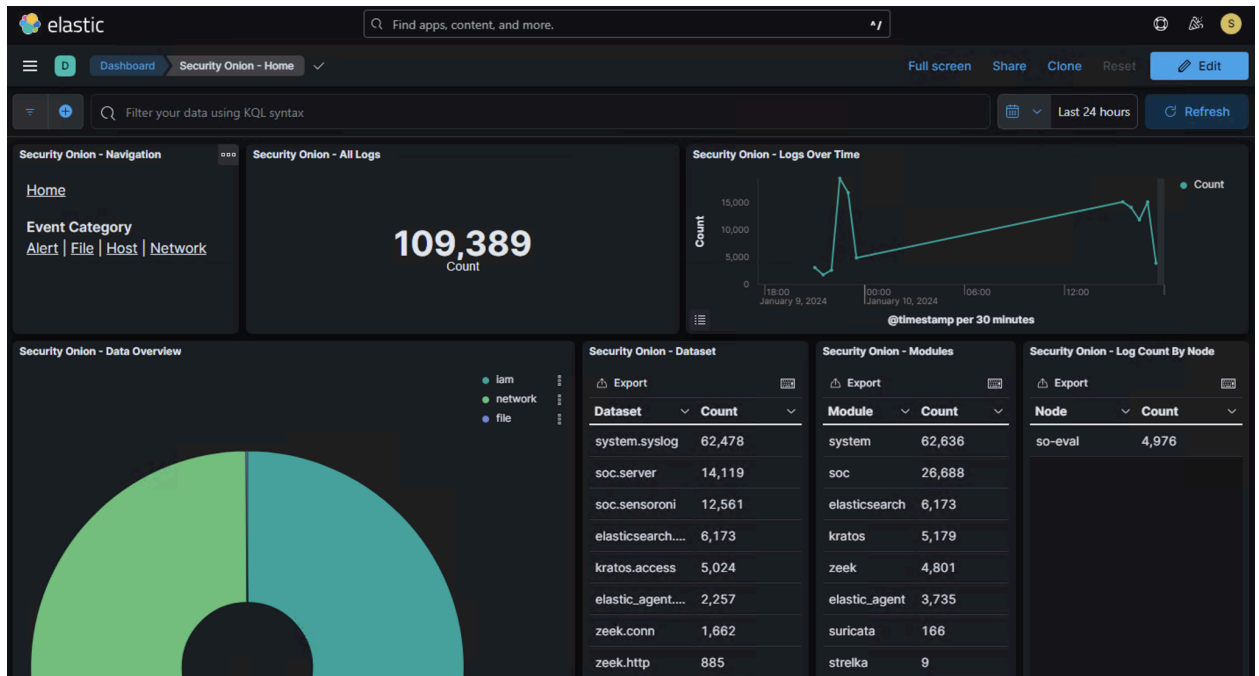
- Next, we'll use Elastic Stack's data analytics engine through Kibana's web-based visualization tool.
- Kibana will allow us to look at and visualize data in different ways.

Launch Kibana by doing the following:

- Click on Kibana located in the bottom left menu.
- A new tab will open, and the Kibana interface will appear.



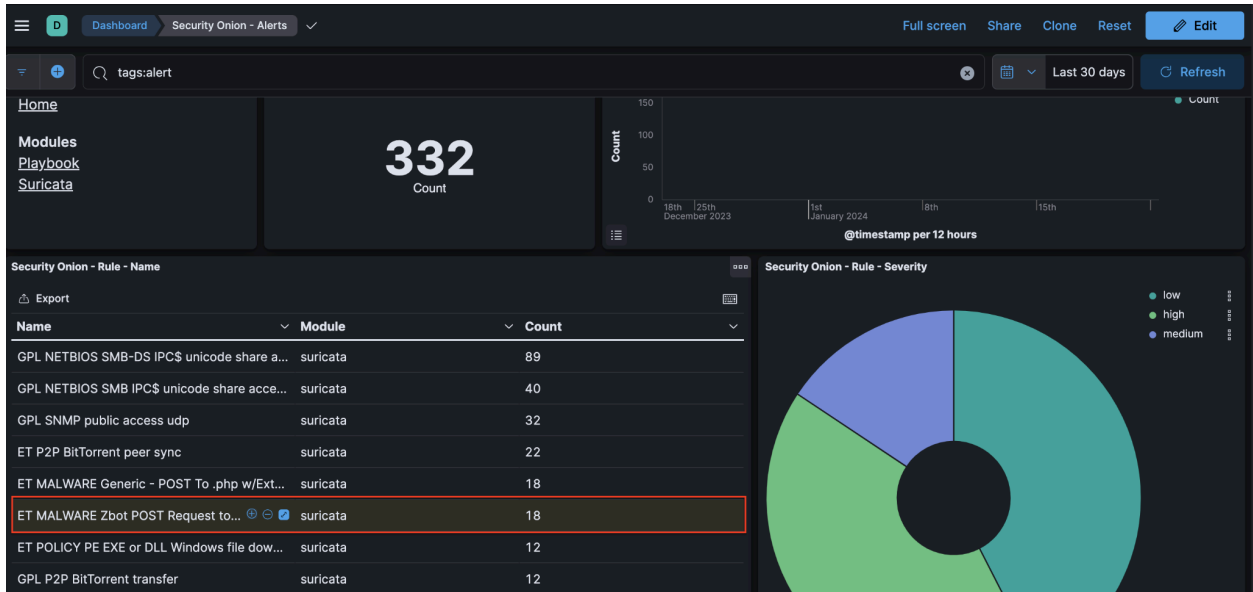
- After Kibana launches, you may be prompted to log in. If so, log in with the same credentials used for the Security Onion client.
 - Once the web browser tab launches, the data should be similar to what is displayed within the Security Onion alerts.



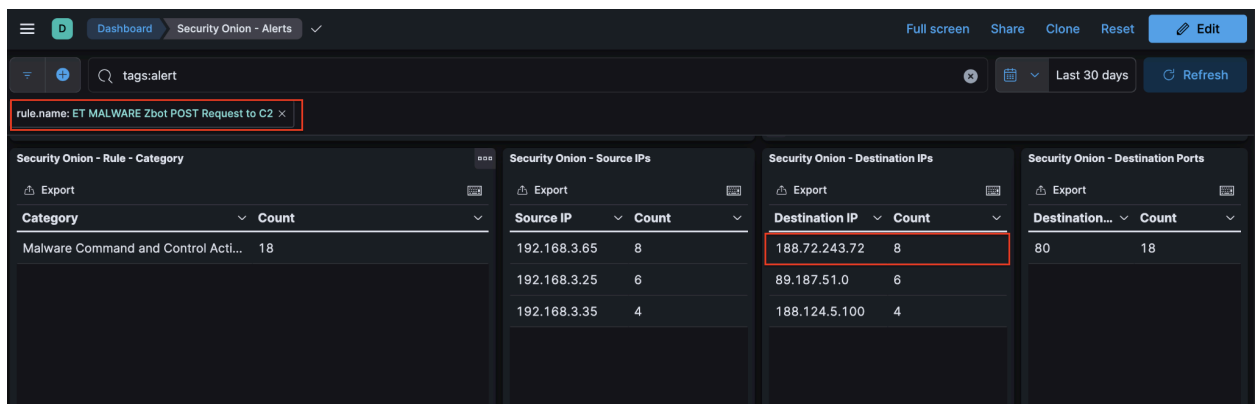
- We have now started using the powerful Elastic Stack data analytics engine.
 - Elastic Stack is the heart of Security Onion's ESM capabilities. Kibana is the interface that provides insight into endpoint telemetry by interpreting the OSSEC agent syslog data.

In this next example, we'll further our investigation by looking deeper into the ET Malware Zbot . . . alert.

- Click the + sign next to the alert.
- This will limit results to just those matching that alert.



- At this point in an investigation, we are looking for more evidence in relation to the Zbot malware.
 - For example, if we look at what non-local IP addresses are being used in this traffic, we might get a clearer picture of what is occurring on the network.
 - Review the image below, there are 8 instances occurring with the remote IP address of 188.72.243.72.



- Let's add destination IP 188.72.243.72 by clicking its + sign.
- Now remove rule.name: ET MALWARE Zbot POST Request to C2 by clicking the x next to it.
- This will now just show us the traffic relating to 188.72.243.72.

The screenshot shows the Elastic Security console interface. At the top, there's a search bar and navigation tabs. Below, four tables are displayed side-by-side, each with an 'Export' button. The 'Security Onion - Destination IPs' table is highlighted with a red box.

Security Onion - Rule - Category		Security Onion - Source IPs		Security Onion - Destination IPs		Security Onion - Destination Ports	
Category	Count	Source IP	Count	Destination IP	Count	Destination...	Count
A Network Trojan was detected	12	192.168.3.65	24	188.72.243.72	24	80	24
Malware Command and Control Acti...	8						
Potentially Bad Traffic	4						

- As we can see from the results, it looks like there is more suspicious traffic coming from 188.72.243.72. We can probably come to the following conclusion.
 - It is likely that there is malicious activity occurring from that IP address.
 - Action should be taken to block all traffic related to that IP address.
 - Further analysis may be required.
- Once we determine an alert needs further analysis, we can update the case and escalate the event to a senior incident handler for further review.
 - Return to your Security Onion tab.
 - Click Cases in the left column.
 - Select Binoculars on the Zbot Malware case.
 - Click Case description . . . and add the following "Possible C2 infection detected" and click Save.
 - Change the Status to in progress.
 - Change the Severity to critical.
 - Add a comment: "Zbot Malware may have been downloaded. The 188.72.243.72 IP address looks suspicious."
 - Click Add.

Zbot Malware

Possible C2 infection detected

COMMENTS

ATTACHMENTS

OBSERVABLES

EVENTS

HISTORY

+

↺

Zbot Malware may have been downloaded. The 188.72.243.72 IP address looks suspicious.

sysadmin@example.com

• Jan 22, 2024 2:05 PM

Summary

Assignee:
unassigned

Status:
in progress

Details

Severity:
critical

Note: In a production environment, the case could be assigned to a senior analyst for more thorough inspection. Under Summary, there is an option to assign the case to another analyst.

We can verify the escalated event by:

- Selecting the Cases from the left column
- Selecting the Binoculars for the Case
- Selecting History
- Verifying the note that was entered by the junior analyst

Summary

- This demonstration covered how to conduct investigations using various threat hunting techniques. We focused on a few of the many ways to start an investigation.
- ESM (enterprise security monitoring) includes endpoint telemetry, host-based monitoring of system data that uses OSSEC collection agents to gather syslog data.
- To investigate network-based IDS alerts, security administrators must use enterprise security monitoring, which includes visibility into endpoint OSSEC agents.
- IDS alerts are snapshots in time. They raise questions that need answers. With the use of Security Onion, security admins can use PCAPs to reconstruct a crime.

06. Activity: Investigation, Analysis, and Escalation

- [Activity File: Investigation, Analysis, and Escalation](#)
-

07. Break

08. Activity Review: Investigation, Analysis, and Escalation

09. Threat Hunting - Cyber Threat Intelligence

Threat intelligence is important at every level of government and public sector organizations, who use it to determine acceptable risk and develop security controls that inform budgets.

Malicious actors have various motivations. For example:

- Hacktivist organizations are politically motivated.
- Criminal hackers are financially motivated.
- Cyber espionage campaigns, most typically associated with nation states, steal corporate secrets.

Knowing the motivations for attacks against your organization will help you determine the security measures necessary to defend against them.

Threat Intelligence Cards

As a member of the Computer and Incident Response Team (CIRT), one of your responsibilities is to establish a threat intelligence card, which documents the TTPs used by an adversary to infiltrate your network.

- When handling a large-scale intrusion, incident responders often struggle with organizing intelligence-gathering efforts.
- Threat intelligence cards are shared among the cyber defense community, allowing organizations to benefit from the lessons learned by others.

Cyber threat intelligence centers on the triad of actors, capability, and intent, along with consideration of TTPs, tool sets, motivations, and accessibility to targets.

- These factors inform situationally aware decision-making, enhanced network defense operations, and effective tactical assessments.

10. Threat Hunting - Cyber Threat Intelligence

- [Activity File: Threat Hunting - Cyber Threat Intelligence](#)

11. Review: Threat Hunting - Cyber Threat Intelligence Activity

- The individual results from this activity will vary. The goal of this activity is intended to demonstrate how cyber professionals can use all of the skills covered in this module to conduct an investigation.